

Продвинутый чеклист по Reson. Не "что запускать", а как думать

Note

Перестань думать про reson как про список действий. Это не "сначала subfinder, потом nuclei". Это не про инструменты. Это про **контекст**.

Когда ты открываешь новую цель — ты не запускаешь тулзу. Ты пытаешься понять:

- Где живёт инфраструктура?
- Как работают их разработчики?
- Где они накосячили?

И только после этого ты уже начинаешь собирать инструменты. Не наоборот.



Чеклист

1. Настрой майндсет

Warning

Если ты просто гоняешь тулзы — ты внизу пищевой цепи.

Reson — это разведка. Разведка — это не сканеры, это мышление.

Ты не просто сканируешь сайт, ты анализируешь инфраструктуру компании.

Твоя задача — **переиграть** DevOps-инженеров и архитекторов.



2. Субдомены

Инструменты: `subfinder`, `amass`, `dnsx`

Tip

Ты находишь `dev.api.target.com`? Это не просто саб. Это намёк:

- Есть dev-среда.
 - Может быть staging.
 - Где-то в цепочке могут быть Jenkins или GitHub Actions.
- Ты не собираешь сабы, ты **строишь модель их инфраструктуры**.



3. HTTPX: быстрое понимание, что живое, что мёртвое

Инструмент: `httpx`

Флаги: `-td -tech-detect -title -web-server -status-code`

Question

Зачем? Чтобы сразу понять:

- Это React за CDN или Laravel с debug mode?
 - Что говорят заголовки?
 - Где у них живёт бэкэнд?
- Это разведка, а не скан.



4. JavaScript

Инструменты: `linkfinder`, `subjs`, `grep`

Example

Даже если JS минифицирован — смотри глазами.

- API-запросы
- Токены

- Странные ключи
- Dev-конфиги

🔍 Однажды я нашёл OAuth токен прямо в комментариях JS. Такое происходит постоянно.



5. Тестируй эндпоинты вручную

Инструмент: `Burp Suite`, вкладка `Repeater`

Tip

Проверяй эндпоинты из JS:

- Без кук
- С разными методами
- Без параметров
- С мусором в теле



6. Пассивный развед

Инструменты: `gau`, `waybackurls`, `github-subdomains`, Google/GitHub Dorks

Info

- Старые admin-панели часто доступны, но не линкуются.
- Поиск по GitHub может выдать `.env`, токены, даже SSH ключи.
- Используй Google Dorks: `site:target.com inurl:admin filetype:pdf`



7. Построй Asset Graph

Tip

Составь карту всего найденного:

- Поддомены
- JS и API
- IP и CDN
- GitHub ссылки
- S3-бакеты

Смотри связи. Найди паттерны. Всё, что они не контролируют — потенциальный вектор атаки



8. Автоматизируй только рутину

Warning

Не автоматизируй мышление — оно твой ключевой актив.

Но автоматизируй грязь:

- `amass` → `subfinder`
- `httpx` для живых
- `nuclei` для первичного поиска
- `linkfinder` для парсинга JS

А вот логику, анализ и выводы — **всегда руками**.



9. Построй свой фреймворк

Example

Минимум, что должен делать твой фреймворк:

1. Собирать сабы
2. Проверять что живо
3. Парсить JS
4. Делать fingerprint
5. Гонять первичные шаблоны nuclei
6. Доставать URL из Wayback
7. Собирать граф связей

Tip

Сделай это в Bash, Python или в Obsidian вручную — главное, **внедри это в практику**.



10. Преврати знания в результат

Info

Не каждый баг = деньги.

Чтобы зарабатывать, надо:

- Уметь выбрать программу
- Написать грамотный отчёт
- Автоматизировать своё время

